# API de autenticação e sessão

Documentação técnica - Manual Operacional Digital

Base: `/api/auth`.

## POST /login

**Acesso:** público.

```
{ "identificador": "admin", "senha": "admin123" }
```

**Fluxo:** valida os campos; verifica bloqueio para a combinação IP + identificador; busca o usuário por `identificador` (ou pelo `email` legado); compara o hash bcrypt. Cada falha conta uma tentativa; na quinta, o login fica bloqueado por 15 minutos. Em caso de sucesso, zera as falhas, grava auditoria `login` e emite o JWT.

Resposta `200`:

```
{
  "token": "eyJ...",
  "user": { "id": 1, "nome": "Suporte Admin", "identificador": "admin", "role": "suporte", "sector_ids":
[], "setores": [] }
}
```

O JWT expira em 8 horas e contém `id`, `nome` e `role`. Os setores não ficam no token: são lidos do banco a cada requisição, então mudar os setores de um usuário vale na hora.

**Erros:** `400` campos ausentes · `401` credenciais inválidas · `429` bloqueado · `500` sem `JWT_SECRET` configurado.

## GET /me

**Acesso:** autenticado.

Retorna `id`, `nome`, `identificador`, `email`, `role`, `sector_ids` (lista de ids), `setores` (lista de `{ id, nome }`, em ordem alfabética) e `created_at` do usuário do token. O frontend usa esta rota ao recarregar a página.

## PUT /password

**Acesso:** autenticado. Troca a própria senha.

```
{ "currentPassword": "admin123", "newPassword": "NovaSenha2026" }
```

**Fluxo:** exige nova senha com 8+ caracteres, uma letra e um número; confere a senha atual; grava o novo hash; registra auditoria `password_changed`.

**Respostas:** `204` sucesso · `400` senha atual incorreta ou nova senha fraca.

## POST /register

**Acesso:** suporte. Cria usuário.

```
{
  "nome": "Maria Silva",
  "identificador": "maria.silva",
  "senha": "Treino2026",
  "role": "usuario",
  "sectorIds": [3, 5]
```

```
}
```

- `role`: `suporte`, `gerente_setor` ou `usuario` (padrão `usuario`).
- `sectorIds`: ids dos setores (um ou mais). Obrigatório para `usuario` e `gerente_setor`; opcional para `suporte`. Os setores precisam existir (são criados em `POST /api/sectors`).
- Senha segue a mesma política da troca de senha.

**Respostas:** `201` com o usuário sem senha · `400` campos ausentes, perfil inválido ou senha fraca · `403` sem permissão · `500` identificador já existente.